

SOC/L1 - 1. Blue Team Introduction

Daily Duties

As a Junior Security Analyst, also called a SOC Level 1 Analyst, you work in a 24/7 SOC team and mostly review the security alerts together with your colleagues. To do it efficiently, you will need practice and skills learned through this path. During your work shift, you would typically:

- Monitor and investigate various security alerts
- Participate in brainstorming and workshops SOC
- Cooperate with other teams to keep your company safe
- Constantly learn and discover new attacks and defenses

| Which team do you work with as a Junior Security Analyst? SOC

Your Daily Duties

- Detect and prevent a data stealer infection on a coworker's laptop
- Analyze and stop a phishing campaign targeting the finance team
- Participate in a bigger incident, such as a full-scale ransomware attack
- Team up with your teammates to build detection rules and automations
- Go beyond cyber and understand how companies operate from the inside

Security Hierarchy

Looking at the diagram above, top executives like the CEO usually focus on global business objectives and don't manage technical aspects. That's why they hire a Chief Information Security Officer (CISO) or a similar role who knows the business needs and can create the most suitable security departments.

Which senior role typically makes key cyber security decisions? CISO

What is the common name for roles like SOC analysts and engineers? Blue Team

Security Operations Center (SOC)

- **L1 Analysts:** Junior members who triage alerts and pass complex cases to L2
- **L2 Analysts:** Experienced members who investigate more advanced attacks
- **Engineers:** Experts in configuring security tools like EDR or SIEM
- **Manager:** A person who manages the whole SOC team

Does Blue Team focus on defensive or offensive security? Defensive

Which department handles active or urgent cyber incidents? CIRT

Cyber Incident Response Team (CIRT)

If SOC expertise is not enough or the incident goes out of control, you urgently call the "firefighters" - CIRT, also called CSIRT or CERT. The members should have a broad knowledge of cyber threats and handle breaches without depending on tools like EDR or SIEM. A CIRT job is stressful and responsible, but also rewarding. Here are a few CIRT examples:

- [JPCERT\(opens in new tab\)](#): Japan's CERT handling nation-wide breaches
- [Mandiant\(opens in new tab\)](#): A private team responding to global cyber incidents
- [AWS CIRT\(opens in new tab\)](#): Investigates security incidents of AWS customers

Specialized Defensive Roles

Large companies, technology-focused startups, and government agencies often require narrow and specialized Blue Team roles - exciting and highly valuable, but requiring deep topic knowledge and broad experience in broader fields like SOC or IT. These narrow roles can include:

- **Digital Forensics Analyst:** Uncover hidden threats in disk and memory
- **Threat Intelligence Analyst:** Gather data about emerging threat groups
- **AppSec Engineer:** Maintain a secure software development lifecycle
- **AI Researcher:** Study AI threats and how to defend against them

Internal SOC vs MSSP

Topic	Internal SOC	MSSP
ScenarioExample	You work in a SOC team of the bank and protect the bank's systems	You work for a global MSSP protecting its sixty customers in Europe
WorkingPace	You usually have calm shifts without too much time pressure	Your shift usually starts from a queue of urgent alerts to analyze
SecurityTools	You work with just a few tools, but need to know them very well	You have to work with sixty diverse security tools and platforms
IncidentPractice	You saw and learned from just two major cyber attacks last year	Every week, you deal with attacks and breaches, and can learn from it

How would you call a cyber security company providing SOC services? MSSP

Which role naturally continues your SOC L1 analyst journey? SOC L2 Analyst

Humans as Attack Vectors



Humans are targeted because of the **access** they can provide - to websites, mailboxes, or databases. Some threat actors hunt for a specific access, while others are not so selective and just breach as many accounts as they can and decide how to use them later. Here are just a few examples of what threat actors hope for when trying to breach humans:

Attack Example	Next Step of Attackers
Breach Google account of the HR manager	Steal and sell the entire employee database
Trick a wealthy person into running malware	Hijack a web banking session from their PC
Breach the IT administrator's VPN account	Access the heart of a big corporate network
Trick a government worker into sharing secrets	Use the information to simplify the next attacks

What or who is the weakest link in cyber security? Humans

What do attackers seek when targeting humans in a cyberattack? Access

Attacks targeting humans share a common trait: they rely on manipulating the victim into helping the attacker, whether knowingly or not. This tactic is known as **social engineering**, and it works by exploiting human psychology rather than technical flaws. For the tactic to succeed, it is designed to be:

- **Trustworthy:** The attacker must appear legitimate so the victim trusts them
- **Emotional:** The attack must trigger feelings like urgency, fear, or curiosity

Phishing Attacks: You receive an email saying, "*Your account has been compromised. Click here for details!*" When you click on the link, it takes you to a fake login page that looks real, but sends your credentials to the attacker. That's phishing in action. Email phishing is the most common form of social engineering, with an estimated 3.4 billion[\(opens in new tab\)](#) malicious emails sent daily.

Malware Downloads: Ever searched for and installed the application on your PC? Well, you might have just installed malware[\(opens in new tab\)](#) on your computer. To make these attacks more successful, threat actors use innovative techniques like fake CAPTCHAs, malicious QR codes, and SEO poisoning.

Deepfakes: The rapid rise of AI-generated video or audio has become more effective in impersonating family members, colleagues, or corporate partners. In one case[\(opens in new tab\)](#), a finance worker received a deepfake video call from someone appearing to be their boss and got tricked into wiring \$25 million for an "urgent business deal".

Impersonation: Even without deepfakes, the attackers are quite successful in pretending to be someone else (impersonating someone). Many recent ransomware attacks([opens in new tab](#)) started with a simple phone call from attackers impersonating a corporate IT department and asking victims to take over their accounts for a quick "system repair".

Other Attacks: This task covered some popular social engineering methods, but there are many more! USB drop campaigns, physical attacks, insider threats, and even fake job offers - all of them are a constant risk to the employees, and you as a SOC analyst should be ready to respond!

What is the name of an attack tactic that manipulates human psychology?
Social Engineering

Which social engineering method is about pretending to be someone else?
Impersonation

Defending Humans

As a SOC analyst, your task is to **detect** and investigate attacks, and you'll have the whole SOC Level 1 path to learn it. However, you'll soon be tired of analyzing all the never-ending attacks and might think about how to automatically prevent common threats. This is why knowing key **mitigation** measures is essential. If your mitigation ideas are approved by IT and top management, you'll ease the SOC routine and make your company more secure! Here are a few examples of how to protect employees:

Mitigation	Description
Anti-phishing solution	SOC routine becomes easier with a tool that blocks phishing emails before the users even notice
Antivirus / EDR solution	A reliable antivirus on all corporate hosts is a great measure to prevent humans from running malware
"Trust but verify" principle	Instruct your employees how to detect deepfakes and verify suspicious requests from "CEO" or "IT"
Security awareness training	Teach your employees how to detect phishing and reinforce training through phishing simulations

Which process is aimed at preventing or reducing the chance of an attack?
Mitigation

Which mitigation measure is about training employees in cyber security?
Security Awareness Training

Systems as Attack Vectors

Definition of System: Each system type can have a different value for threat actors, for example:



Breached System	Attack Value
A personal laptop of a school student	Steal Steam profile and add the PC to a botnet
A laptop of the bank's senior IT administrator	Get access to the internal banking systems
A mail server of a criminal law company	Dump all mailboxes and blackmail the victim
A server at the heart of an industrial network	Encrypt the whole network with ransomware
A government website management panel	Damage the website content (defacement (opens in new tab) / activism)

Can cyber attacks happen without victim intervention (Yea/Nay)? Yea

Can a breach of just a single system lead to disastrous consequences (Yea/Nay)? Yea

Attacks on Systems

Human-Led Attacks: It's no surprise that system users are often those who start the attack: By inserting a malicious USB found on a street, downloading malware from pirated resources, or simply reusing a weak password everywhere. 81%

[\(opens in new tab\)](#) of breaches involve stolen or breached passwords - [check out\(opens in new tab\)](#) your passwords too!

Vulnerabilities: Every piece of software can have security flaws. In 2024, [over 40,000\(opens in new tab\)](#) software vulnerabilities were published and [more than 300\(opens in new tab\)](#) were actively exploited in major attacks. Moreover, IT administrators often increase the risks by setting weak passwords and allowing unrestricted access to their systems.

Supply Chain: Your PC is home to hundreds of apps, including web browsers, messengers, development, and entertainment software. Every app depends on thousands of libraries. If threat actors manage to breach one of the apps or libraries and push an update to all its users, all of them will be compromised. This technique is called a supply chain attack. The most famous examples are the [SolarWinds\(opens in new tab\)](#) and [3CX\(opens in new tab\)](#) breaches which affected thousands of companies.

Emerging Threat of Supply Chain: It is hard to protect from supply chain attacks since you can't always control all the software present on your laptops, servers, and web apps. Even TryHackMe once [fell victim](#) to a supply chain in Lottie Player, a library used for room animations. As a SOC analyst, you must be ready for such scenarios and know how to respond!

What is the term for a security flaw that can be exploited to breach a system?
Vulnerability

What is the name of the attack when malware comes from a trusted app or library? Supply Chain

Vulnerabilities

Software Vulnerabilities: Every piece of software has flaws, but some take years to be discovered. For example, [Shellshock\(opens in new tab\)](#), a major Linux vulnerability, existed since 1992 but wasn't found until 2014. In the worst-case scenario, attackers discover the vulnerability before anyone else. This is known as a [zero-day\(opens in new tab\)](#), and only your SOC skills can determine whether it gets detected in time. Once a vulnerability is made public, it is assigned a Common Vulnerabilities and Exposures ([CVE\(opens in new tab\)](#)) number. From

that moment, it's a race: attackers develop exploits while defenders rush to update their systems. Here is the timeline of how Windows vulnerabilities evolve every year:

Responding to Vulnerabilities: An answer to a CVE is always a **patch** - an update supplied by the software vendor. Even for zero-days, you'll have to wait for a patch, vigilantly monitor for exploitation traces, and try to survive the stressful period before the patch is released. For example, by:

- Restricting access to the system to only trusted IPs
- Applying temporary measures provided by the vendor
- Blocking known attack patterns on IPS or WAF

| What is the CVE for the critical SharePoint vulnerability dubbed "ToolShell"?

| How would you respond to a detected vulnerability on your system?

Misconfigurations

On the other hand, a misconfiguration isn't a bug in the software but a mistake in how the system was set up, often by the IT team. These errors happen frequently, usually to make things simpler, like using "1111" instead of typing a long password every time. Let's take a look at some real-world examples.

- How ["123456" password\(opens in new tab\)](#) exposed chats for 64 million McDonald's job applications
- How a [misconfigured AWS cloud\(opens in new tab\)](#) resulted in a breach of 106 million bank customers
- How improperly configured [smart fridges\(opens in new tab\)](#) are silently used in full-scale botnet attacks

Responding to Misconfigurations: Misconfigurations do not require a software update - just a better setup. As a SOC analyst, you'll often spot them only after threat actors exploit them. However, in smaller companies, you might also be responsible for a more proactive response, for example:

- **Penetration Testing:** Hire ethical "hackers" who simulate an attack and report on discovered security flaws

- **Vulnerability Scans:** Periodically run tools that can detect default passwords or outdated software
- **Configuration Audits:** Manually review the systems to match best practices like CIS benchmarks

| Can a system patch or software update fix the misconfigurations (Yea/Nay)?

| Which activity involves an authorized cyber attack to detect the misconfigurations?